

POL-011

Digital Operational Resilience (DORA) Policy

Group Functions | Digital Banking & Payments

Policy ID	POL-011
Version	v1.0
Effective Date	17 January 2025
Next Review	17 January 2026
Status	Active
Policy Owner	Group CIO
Applies To	Group Functions Digital Banking & Payments
Classification	INTERNAL — All KBC Group Employees

About this policy: This policy explains how KBC maintains the resilience of its digital platforms — managing ICT risk, overseeing technology suppliers, responding to incidents, and testing our ability to withstand disruption.

How to use this policy

This policy is written for all KBC employees. It explains what we stand for, what is expected of you, and how to handle situations you may encounter in your day-to-day work. You do not need to be a legal or compliance expert to read it. If you are ever uncertain, the right thing is always to ask. Contact details for your Compliance team are at the end of this document.

Contents

- 1 Introduction
- 2 Who This Applies To
- 3 What Digital Operational Resilience Means
- 4 How We Manage ICT Risk
- 5 Managing Our Technology Suppliers
- 6 When Systems Fail — Incident Management
- 7 Testing Our Resilience
- 8 Your Responsibilities
- 9 Getting Help
- 10 Policy Review

1. Introduction

KBC is a digital bank. Our customers rely on KBC Mobile, KATE, and our online banking platforms to manage their money every day. The resilience of those platforms is fundamental to the trust our customers place in us. This policy sets out how KBC manages digital operational resilience across our entire technology estate.

2. Who This Applies To

This policy applies to all KBC employees who manage, maintain, use, or make decisions about KBC's technology infrastructure — particularly those in IT, cybersecurity, technology governance, and vendor management.

3. What Digital Operational Resilience Means

Digital operational resilience means the ability of KBC to maintain all our critical functions even when things go wrong — whether that is a cyber attack, a system failure, a natural disaster, or the failure of a technology supplier. KBC Mobile and KATE are our most mission-critical platforms. If either is unavailable, millions of customers are immediately affected. These platforms have recovery time objectives measured in hours, not days.

4. How We Manage ICT Risk

ICT risk management begins with understanding what we have. KBC maintains a complete inventory of its technology assets and maps the dependencies between them. We apply security controls at every layer: network security, access controls, encryption, anomaly detection, and continuous monitoring. These controls are reviewed and tested regularly.

5. Managing Our Technology Suppliers

KBC relies on external technology providers for significant parts of its infrastructure, including cloud services and the large language model that powers KATE. These third parties have access to sensitive data and systems, which means their resilience and security directly affects ours. All critical technology suppliers are subject to rigorous due diligence and contractual obligations covering audit rights, data security standards, exit arrangements, and sub-contracting controls. We test our exit arrangements annually.

Why the AI vendor matters

Since October 2025, KATE runs on GPT-4.1, provided by OpenAI. That makes OpenAI a critical technology supplier for KBC. We apply the same rigorous oversight to AI model vendors as we do to any other critical ICT provider — including the right to audit their systems and clear obligations on data security and service continuity.

6. When Systems Fail — Incident Management

Despite our best efforts, systems will sometimes fail. What matters is how quickly and effectively we respond. KBC has a documented incident response process with clear escalation paths, communication responsibilities, and recovery procedures. For significant incidents, we are required to notify our regulators promptly — often within 24

hours. Your prompt internal reporting makes that possible.

7. Testing Our Resilience

Resilience is not just claimed — it is tested. KBC conducts regular resilience testing including penetration testing, disaster recovery exercises, and scenario-based tabletop exercises. Every three years, KBC's most critical systems are subject to adversarial Threat-Led Penetration Testing, carried out by certified specialists who replicate the tactics of real-world attackers.

8. Your Responsibilities

- Report system anomalies and security concerns immediately.
- Follow incident response procedures precisely.
- Raise concerns about third-party technology suppliers through proper governance channels.
- Participate in resilience testing exercises when required.

9. Getting Help

- **IT Security / Group CIO Office** — for resilience and incident questions.
- **KBC Compliance Advisory** — for policy guidance.
- **KBC Ethics & Compliance Helpline** — for confidential concerns.

10. Policy Review

This policy is reviewed annually and following significant incidents or regulatory developments.